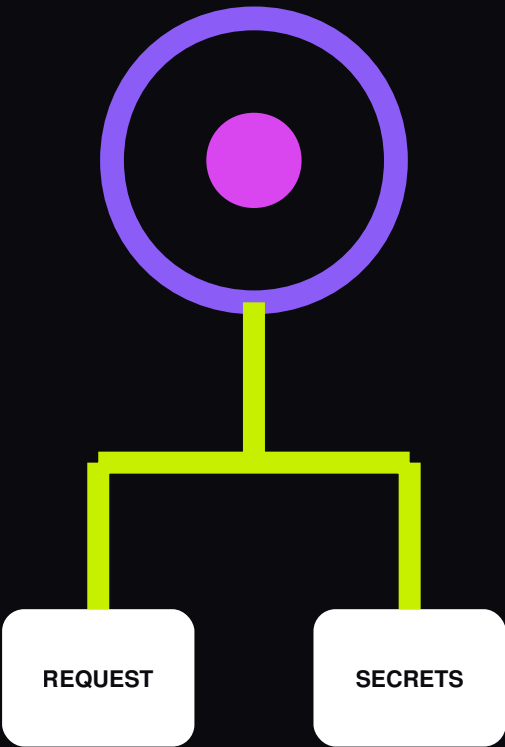


ANONYMOUS FILE.PATH SECRET- TARGET REQUEST

Detects GitLab's official high-signal request shape: anonymous POST, empty file part, content-type, file.path, and a configuration or secrets filename.

PRODUCTION CANDIDATE

CONFIDENCE: MEDIUM



EVIDENCE BEFORE ALERTING

REPORT DATE	STATUS
15 September 2026	Untested implementation sketch
PRIMARY PLATFORM	OPERATIONAL VALUE
Splunk	9.8 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

9.8

Detects GitLab's official high-signal request shape: anonymous POST, empty file part, content-type, file.path, and a configuration or secrets filename.

STATUS

Production candidate

Untested implementation sketch; Confidence Medium.

1primary table

0joins

0secondary rules

2validation gates

Evidence boundary

A match proves a high-signal exploitation attempt, not a successful file read, credential theft, session forgery, code execution, or actor attribution. Status 2xx requires immediate escalation but still needs corroboration.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 GitLab fixed CVE-2026-85706 in 19.1.8, 19.2.6, and 19.3.2 on 10 September 2026.
- 2 GitLab published three threat detections after CISA added the flaw to KEV on 11 September 2026.
- 3 The selected official detection records the complete multipart request shape in Rails api_json.log.

Detection hypothesis

If an attacker submits the CVE-2026-85706 request shape, raw GitLab api_json.log should show an anonymous POST with empty file, content-type, file.path, and a config/secrets target. Distinguish it through the complete shape and authorized-testing records.

Unconfirmed elements

A match proves a high-signal exploitation attempt, not a successful file read, credential theft, session forgery, code execution, or actor attribution. Status 2xx requires immediate escalation but still needs corroboration.

Logic: Behavioral, vulnerability-specific **ATT&CK:** T1190 · T1552.001



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

Self-managed GitLab Rails api_json.log ingested as one compact JSON record per Splunk event, with params preserved and no truncation.

OPTIONAL ENRICHMENT

Running version, internet exposure, reverse-proxy/WAF evidence, authorized scanner inventory, correlation_id, and subsequent token, session, repository, or CI activity.

Fields	Reliability	Use
_raw, _time, host, source, sourcetype	Documented / environment-dependent	Query or triage
method, status, params	Present in source	Query or triage
meta.client_id, meta.user	Present in source	Query or triage
remote_ip, route, path, ua	Present in source	Query or triage
environment, correlation_id	Present in source	Query or triage

Excluded

No message body, phishing-page content, inferred success, actor attribution, or undocumented cross-SIEM mapping is used.



PRIMARY SPL

Direct source-supported conditions with investigable output.

DETECTION

STATUS

Production candidate — Untested implementation sketch

SPL — UNTESTED

```
index=<CUSTOMER_INDEX> sourcetype=<VERIFY_SOURCETYPE>
| search _raw="*"method\":"POST\"*"
  _raw="*"meta.client_id\":"ip/*"
  _raw="*"key\":"file\","value\":"\\""
  _raw="*"key\":"content-type\\""
  ( _raw="*file.path*" OR _raw="*file%2epath*" )
  ( _raw="*gitlab.yml*" OR _raw="*secrets.yml*"
    OR _raw="*database.yml*"
    OR _raw="*gitlab-secrets.json*" )
| table _time host source sourcetype _raw
```

WINDOW	THRESHOLD	JOIN	KEY
None	None	None	Raw correlation_id



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain the full raw event, source IP, timestamp, status, route, target path, and correlation_id.

2

Confirm

Confirm anonymous client semantics, target path, response status, running version, and authorized testing.

3

Enrich

Running version, internet exposure, reverse-proxy/WAF evidence, authorized scanner inventory, correlation_id, and subsequent token, session, repository, or CI activity.

4

Scope

Review GitLab component logs and subsequent token, session, repository, runner, and CI activity.

Expected benign overlap

Authorized atomic or patch testing, coordinated research, internal scanners, and a misconfigured tool that submits a host path instead of bytes. Use time-bounded, owner-backed exclusions only.

Response boundary

A match proves a high-signal exploitation attempt, not a successful file read, credential theft, session forgery, code execution, or actor attribution. Status 2xx requires immediate escalation but still needs corroboration.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

- 1. Confirm compact single-event JSON and unredacted params in Splunk.
- 2. Use GitLab's decoy-file atomic test on a patched non-production instance.
- 3. Confirm one match and classify status 400 as the safe rejected outcome.
- 4. Review 30 days against scanner inventory and pivot on correlation_id.

Decision criteria

Success: The controlled decoy test produces a complete, investigable match and authorized sources are attributable.

Rejection: The request-shape conditions are not preserved or benign overlap cannot be separated.

Failure: params are redacted, multiline, truncated, not ingested, or assigned to the wrong sourcetype.

Platform	Decision	Missing evidence
Splunk	Production candidate	Raw request shape and local baseline
Microsoft Sentinel	Atomic validation only	Syslog ingestion and line integrity
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Production candidate

Detects GitLab's official high-signal request shape: anonymous POST, empty file part, content-type, file.path, and a configuration or secrets filename.

A match proves a high-signal exploitation attempt, not a successful file read, credential theft, session forgery, code execution, or actor attribution. Status 2xx requires immediate escalation but still needs corroboration.

MITRE ATT&CK

T1190 · T1552.001

References

1. GitLab — Critical Patch Release 19.3.2, 19.2.6, 19.1.8 — 10 Sep 2026
2. GitLab Security OSS TLDR — LFI attempt reading gitlab.yml — 14 Sep 2026
3. Pruva — CVE-2026-85706 end-to-end reproduction — 12 Sep 2026
4. CISA KEV — CVE-2026-85706 added 11 Sep 2026
5. MITRE ATT&CK — T1190 and T1552.001

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.